

Broken Authentication **&** **Broken Access Control**



What is Broken Authentication

Broken Authentication is one of the OWASP top 10 issues. When a web application lets users access the website by making a new account, using it for particular purposes and the user logs into a website under a Broken Authentication issue, a session is established and a session ID is created which is limited to that specific user account only. However, if the application is not designed securely with regards to proper authentication, then an attacker may employ several tactics such as Credential Stuffing, un-hashed passwords, and misconfigured session timeout to exploit the issue.

There are several reasons which could lead to Broken Authentication such as inadequate policy for passwords, sending login credentials using an unsecured channel or password access system that is not secure, and information leaked when attempting to log in or when the attempts to log-in is not limited

Impact:

There are several impacts of Broken Authentication vulnerability, such as:

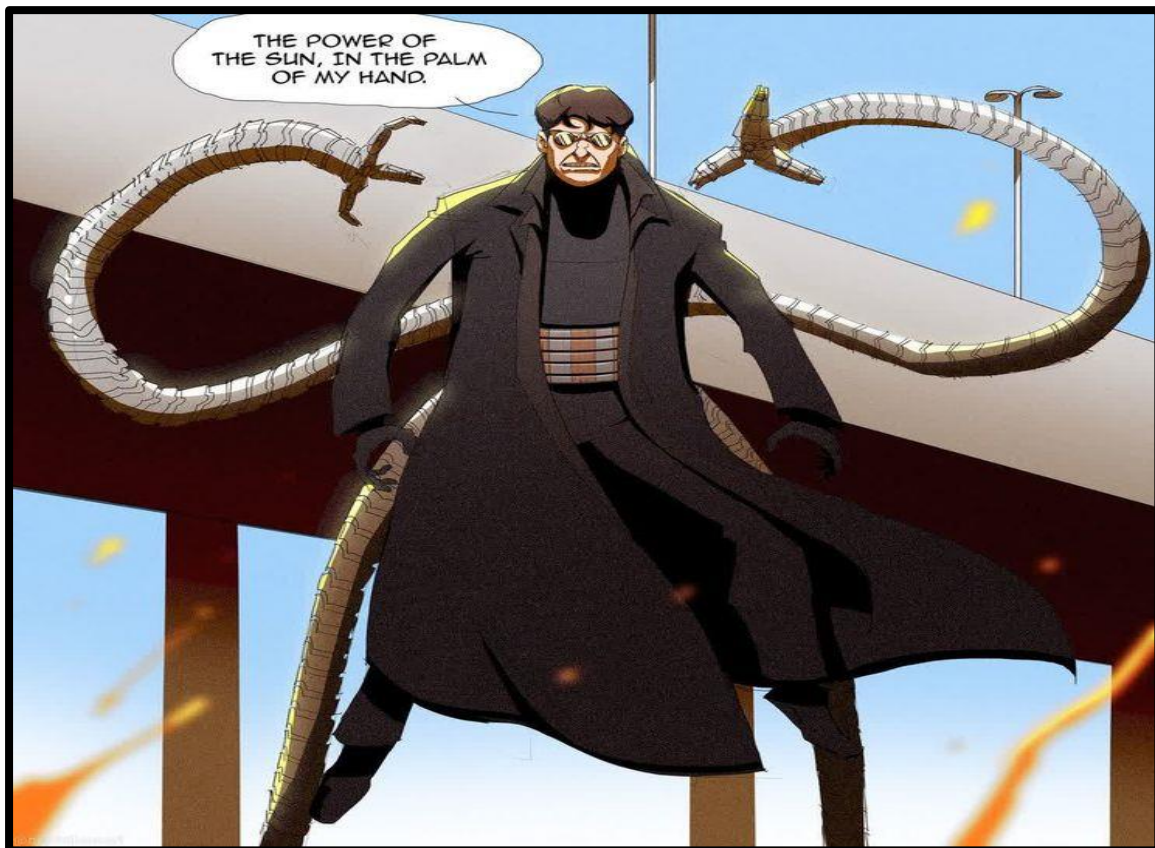
- Exposure to numerous User Accounts
- Data Breaches
- Administrative Access
- Sensitive Data Exposure
- Identity Theft
- Damage to confidentiality.
- Damage to reputation and business loss.

Remediation:

A web application can take the following corrective measures to protect itself from these kinds of attacks:

- Multifactor Authentication must be put into place to thwart these attacks
- A strong/complex password is required for each user account
- After a successful login, session IDs are validated and rotated
- Make use of a stable, server-side built-in session manager that, upon login, creates a new, highly unpredictable random session ID. Session IDs should be safely maintained and invalidated after logout, idle, and complete timeouts
- Limit the number of unsuccessful log-in attempts

What is Broken Access Control



Access control is a security feature that limits resource access and establishes who or what can access or utilize the resources of an organization. It establishes what authorised users are permitted to perform and is verified upon authentication. Inadequate execution of access control protocols results in faulty access control that is readily bypassed. We call this broken access control because, unauthorized individuals might see things they are not supposed to observe, carry out illegal actions, remove content, or even take over the management of the website.

There are several reasons which could lead to Broken Access Control such as intercepting authentication of access control by altering the URL, HTML page, and internal application state, tampering, or reusing metadata to elevate rights, and misconfiguration with CORS (Cross-Origin Resource Sharing) that enables unauthorized access to the API

Impact:

- Unauthorized access
- Data Exposure
- Privilege escalation
- Data loss or corruption
- Account compromise
- Security bypass
- Disruption of service
- Financial loss
- Regulatory non-compliance (Legal Penalties)
- Reputation damage
- Operational overheads
- Long-term consequences

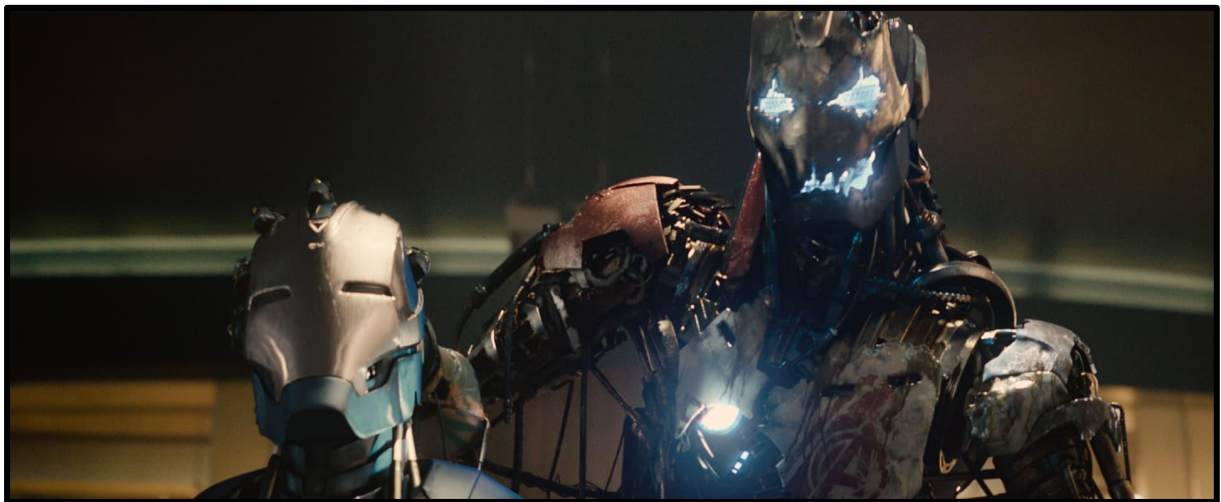
Remediation:

- Constant Testing and Inspection of Access Control
- Refuse Entry by Default: Unless the system is meant to be publicly open, design it so that certain users can only access certain resources and features.
- Restricting CORS Use: If the CORS protocol is set incorrectly, it can allow requests to be sent to your domain from a domain that is under the control of a hostile entity.
- Turn on RBAC or role-based access control
- Turn on Access Control Based on Permissions
- Turn on Mandatory Access Control (MAC): This security feature limits access to resources according to how sensitive the data they hold is. Administrators have central control over the security policy, which ordinary users are unable to alter.

Authorization vs Authentication

Authorisation:

For example, **person A is admin** such as **Clark Kent is Superman, Bruce Wayne is Batman** and **Tony Stark is Iron Man**. Everybody is granted certain privileges that are exclusive to them. Breaking that leads to privilege escalation. Such as, when **Ultron** had unauthorized control over all of **Tony Stark's** suits/bots which tony was building even Jarvis, once.



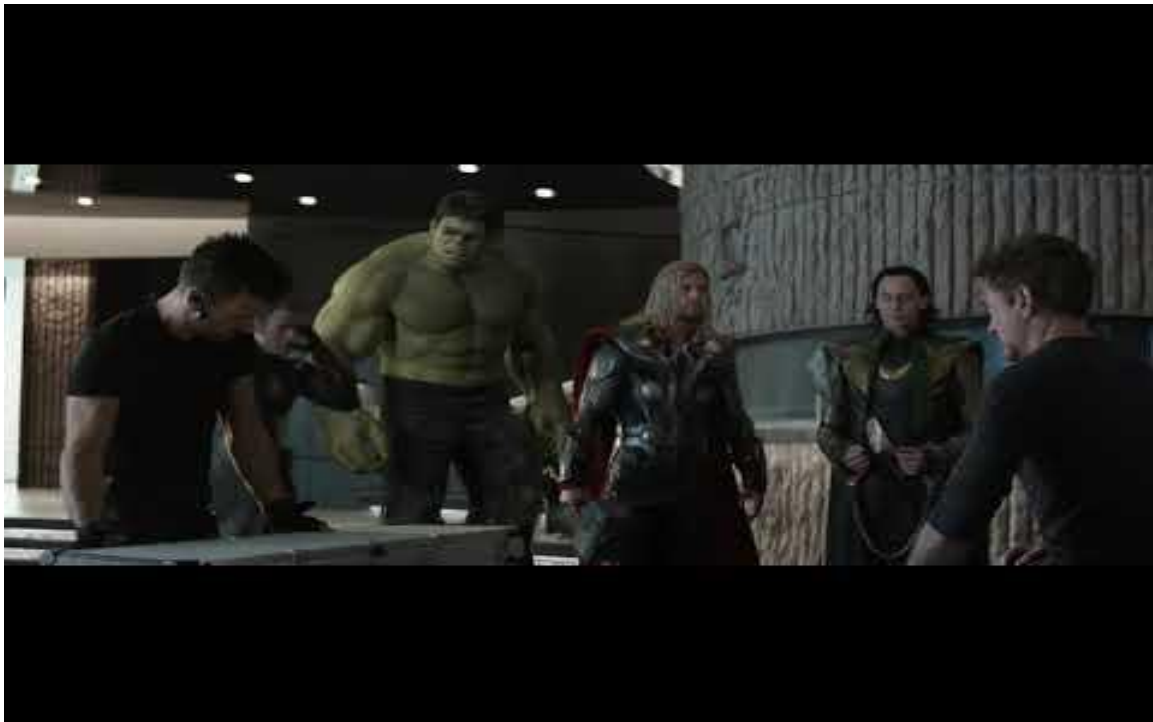
Authentication:

For example, **person A** while logging in must confirm it is **person A** who is trying to log in and not someone else. To prove that **you** are **“YOU”**

Example 1: Tony Stark needs to be **Tony Stark** to operate **Jarvis/Ironman's Suit**. **Thanos** cannot operate **Jarvis**. Access control problems might also arise from flawed authentication as you can see in the picture above. If **Thanos** somehow gets access to **Tony Stark's credentials** (here, I am using the word credentials just for an example). He will be **able to control Jarvis** too just like once Ultron took over Jarvis

Note: *(Thanos could never do that, he is from TITAN and I am not sure about the education system there.)*

Example 2: Loki is a great example for both authentication and authorization as he can transform himself into anyone which could lead to misusing their rights as well



Here is one Authentication vs Authorization table for notes

AUTHENTICATION	AUTHORIZATION
• Usually the first step of a security access control	• Usually comes after authentication
• Verifies the user's identity	• Grants or denies permissions to the user do something
• Common methods include: username, password, answer to a security question, code sent via SMS or email	• Permissions are granted and monitored by the organization
• Uses biometric data like fingerprint, face recognition, retinal scan	• Common methods include: role-based access control and attribute-based access control
• It's visible by the user	• It's not visible by the user
• It's changeable by the user	• Cannot be changed by the user

<https://www.outsystems.com/blog/posts/authentication-vs-authorization/>

Conclusion:

Authorization and authentication are essential to security design even if they are entirely separate ideas. Perception errors regarding both can jeopardize security. Both permission and authentication safeguard resource access. You will not be able to use a resource if you cannot authenticate yourself. One remains unlikely to be allowed access to that resource even if you can provide identification. Even though they frequently appear to be used in the same context, they are not the same at all. Not implementing proper security measures can lead to leakage of sensitive information which can further lead to security as well as reputational damage.

References:

Please refer to the below links for a detailed explanation

- https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- <https://medium.com/@shivamsharma.ss484/broken-access-control-82dfb99949af>
- <https://www.prplbx.com/resources/blog/broken-access-control-vs-broken-authentication/>